Handoff 07: Server-side sessions and logout (stage 7: SEC-03)

Date: 2026-10-25 (America/Toronto)
Written by: Claude Code (implementer)
For: the human maintainer, and ChatGPT or Claude chat (reviewer) without repository access
Status: **in_review**: one pull request, not merged, not deployed. No change to who can sign in, the age rules, XP or content. **Merging signs every user out once** (section 5).

> **How to use this file:** upload it with `build.md`, `docs/plan/backlog.md`, `docs/plan/feedback-security.md` and handoff 06. It summarizes evidence; the pull request diff and CI results are the source of truth (`build.md` section 14).

Starter prompt for the chat assistant

```
You are reviewing Python Academy stage 7 (SEC-03): server-side sessions,
so that logout ends a session at once and a copied cookie stops working.
I'm attaching build.md, the backlog, the feedback security plan, handoff
06 and this handoff. Check that no authenticated route can be reached
without a live session row, that a forged, tampered, expired, logged-out
or old-format cookie is refused, that a deleted user's sessions end, and
that nothing logs a session ID, cookie, email or user ID. Question the
7-day and 24-hour limits. Explain at a first-year computer engineering
level.
```

1. Where we are

Stage	What	Status
1–3	Content format, migrations and ledgers, catalog UI	Verified live (PRs #5, #7, #8)
4	Goals and recommendations	**Verified live** 2026-10-25 (recorded in this PR)
5	Backlog, feature plans, feedback security	Verified (PR #10, documentation)
6	SEC-01 rate limits, SEC-04 security headers	**Verified live** 2026-10-25 (recorded in this PR). The page CSP is still Report-Only
7	SEC-03 server-side sessions	**in_review**: this PR

2. Handoff record (build.md template)

Field	Value
Task	Record the stage 4 and stage 6 live checks; keep `CLIENT_IP_HEADER` across rebuilds; SEC-03: server-side sessions, logout revokes at once, absolute and idle limits, migration, tests
Human goal	A stolen or copied session cookie stops working when the learner logs out, and cannot be kept alive forever. Needed before the admin inbox (FB-06)
Repository and branch	`torontojohn/python-academy`, branch `sec/server-sessions`
Base commit	`4ebdf0d` (`main` after PR #12)
Implementer / reviewer	Claude Code / owner, plus ChatGPT or Claude chat
Deployment status	Not deployed; not merged
New dependencies	**None.** Uses the existing Starlette session middleware (signing), SQLAlchemy, Alembic and Python's `secrets` and `hashlib`

Files changed

File	Change
`backend/app/sessions.py`	New. Starts, looks up and ends sessions; the 7-day and 24-hour limits
`backend/app/db.py`	New `UserSession` model (`sessions` table)
`backend/migrations/versions/0006_server_sessions.py`	New migration: adds the `sessions` table only
`backend/app/main.py`	`current()` finds the user through the session row; the Google callback starts a session; logout deletes it and records `signed_out` in the account history; the cookie's browser lifetime is 7 days
`backend/app/limits.py`	Per-user rate limits find the user through the session row, so a revoked cookie no longer counts as signed in
`backend/tests/test_sessions.py`	New: 43 tests (section 7)
`backend/tests/test_academy.py`, `test_limits.py`	Test sign-in now creates a real session row instead of signing a user ID into the cookie

File	Change
`backend/tests/test_migrations.py`	Head is 0006; new test that deleting a user deletes their sessions on SQLite and PostgreSQL
`render.yaml`	`CLIENT_IP_HEADER=cf-connecting-ip` on the API service
`DEPLOYMENT.md`	`CLIENT_IP_HEADER` is required and in `render.yaml`; what happens without it; new section "Sign-in sessions"
`docs/plan/backlog.md`, `course-catalog.md`, `feedback-security.md`, handoff 06	Stage 4 and stage 6 live checks recorded; SEC-01 verified; SEC-04 headers checked, enforce mode pending; SEC-03 in_review

3. Recorded from the owner's live checks (documentation only)

- **Stage 6 passed on 2026-10-25:** the spoof tests, the `Retry-After` header, separate counters for a phone and a Mac, and the headers. Production uses `CLIENT_IP_HEADER=cf-connecting-ip` on the API service. The temporary diagnostic is switched off. Recorded in handoff 06 section 13.7 and the backlog (SEC-01 verified; SEC-04 stays in_review only until the page CSP is switched to enforce mode).
- **Stage 4 passed:** the goal card, Change goal then Cancel, and `migration 0005` in the API logs. Stage 4 is verified in the backlog.
- `CLIENT_IP_HEADER` **survives a rebuild:** it is now in `render.yaml` with the value already set in the dashboard, so syncing the Blueprint changes nothing. `DEPLOYMENT.md` says that **without it, all signed-out visitors share one counter** (60 preview checks a minute and 60 sign-ins per 10 minutes across the whole site).

4. SEC-03: how sessions work now

Before

The cookie, signed with `SESSION_SECRET`, contained the user ID (`{"uid": 7}`). The server trusted any correctly signed cookie. Logout only told the browser to forget it. Found while doing this: Starlette re-signs the cookie on every response, so its 24-hour expiry restarted with each use. **A copied cookie worked after logout, and for as long as it was used at least once a day.**

After

- **The cookie** is still signed with `SESSION_SECRET`, but holds only `{"sid": "<43 random characters>"}` (32 bytes from `secrets.token_urlsafe`). It holds no user ID or email. It stays `HttpOnly`, `SameSite=Lax`, and `Secure` in production.

- **The `sessions` table** (migration 0006):

Column	Meaning
`id`	SHA-256 digest of the session ID. The ID itself is never stored, so a copy of the table or a backup cannot be turned into a working cookie (tested)
`user_id`	The account. `ON DELETE CASCADE`: deleting a user deletes their sessions
`created`, `last_seen`, `expires`	Whole Unix seconds (UTC), so expiry is a plain number comparison on both SQLite and PostgreSQL

- **Every authenticated request** looks up the row once (cached for the rest of the request). It is refused with 401 if the row is missing, past `expires`, unused for 24 hours, or its user no longer exists. A refused row is deleted and the browser's cookie is emptied.
- **Logout** deletes this browser's row and empties the cookie. A copy of the old cookie then gets 401 on the next request. Other devices stay signed in (tested). The account history now shows "signed out".
- **Signing in** always creates a new random ID, and deletes this browser's previous session if it had one. That prevents session fixation: an ID someone planted before sign-in is never upgraded.
- **Clean-up:** each sign-in also deletes every expired row. No scheduled job is needed, and the table stays at about one row per browser signed in during the last week.
- **Database writes:** `last_seen` is written at most once every 5 minutes per session, so most requests only read. That makes the idle limit accurate to within 5 minutes.
- **Logs:** nothing about sessions is logged. A test signs in, practises, logs out, replays the old cookie and lets a session expire, then checks that the logs contain no session ID, digest, cookie, email or user ID.

Lifetimes chosen

Limit	Value	Why
Idle timeout	**24 hours** without a request	Same as the old cookie's effective behaviour, so learners are not signed out more often than today. Short enough that a cookie left on a shared family computer dies by the next day
Absolute lifetime	**7 days** after sign-in, however much it is used	New. Stops a copied cookie being kept alive forever. Re-signing in with Google once a week is quick, because Google remembers the account

Both are constants at the top of `backend/app/sessions.py`. Shorter admin sessions (`feedback-security.md` suggests 8 hours) become one value set when the session row is created, to be added with the admin role (FB-03).

What this does not do

- It does not detect a stolen cookie that is still in use. Logout, the 24-hour idle limit and the 7-day limit are what end it.

- There is no "sign out everywhere" button. Each browser signs out on its own. Deleting a user's rows would do it; that is a small follow-up if you want it.
- Changing `SESSION_SECRET` still signs everyone out, as before.

5. What happens at deploy

- **Everyone is signed out once**, including you. Their old cookies hold a user ID, which the new code ignores and removes. They see the welcome screen and sign in with Google again. Nothing else changes: role, family links, progress, XP, badges and goals are in the database, not the cookie.
- The migration only adds a table, so the old version keeps working during Render's zero-downtime switch. For the few seconds both versions run, someone who signs in on the new version and is then served by the old one may be asked to sign in again.
- **Rollback:** reverting to the previous version leaves the `sessions` table unused and signs everyone out again. Old-format cookies are removed by the new code on first use, so a rollback does not bring them back.

6. Acceptance criteria

- Stage 6 and stage 4 live checks recorded; `CLIENT_IP_HEADER` in `render.yaml` and `DEPLOYMENT.md`, with the shared-counter note. **Met.**
- The signed cookie holds only a random session ID; the database holds user, created, last seen and expires. **Met** (the table stores a digest of the ID).
- Logout deletes the row so the old cookie stops working at once. **Met** (tested, and checked on a local server with PostgreSQL).
- Absolute lifetime and idle timeout, with the choice explained. **Met** (7 days, 24 hours; section 4).
- Alembic migration. **Met** (0006, tested on SQLite and PostgreSQL).
- No session IDs, cookies, emails or user IDs logged. **Met** (tested).
- Users signed out once at deploy, stated in the handoff. **Met** (section 5).
- Tests: logout, expired, forged or tampered, deleted user, every authenticated route still works, and a test that fails if a new authenticated route skips the session check. **Met** (section 7).
- No change to who can sign in, age rules, XP or content; no new dependencies. **Met.**

7. Tests run (exact commands and results)

From the repository root, on macOS with Python 3.12.14 (`backend/.venv`) and Node 24:

Command	Result
`cd backend && .venv/bin/python -m pytest -q tests/test_sessions.py`	`43 passed`
`cd backend && .venv/bin/python -m pytest -q`	`177 passed, 9 skipped` (the 9 are PostgreSQL tests; they need `TEST_POSTGRES_URL`)

Command	Result
Same, with `TEST_POSTGRES_URL` set to a local throwaway PostgreSQL 16 (pgserver)	`186 passed`
`cd frontend && npm run build`	Compiled successfully (frontend unchanged)
`cd frontend && CI=1 npm run test:e2e`	`27 passed`
Local uvicorn with PostgreSQL, a session started with `sessions.start()`, then `curl`	Log `Database schema is at migration 0006`; `/api/me` 200, `/api/progress` 200, logout 200, same cookie on `/api/me` **401**, 0 rows left, 0 log lines containing the session ID or email

CI runs the backend tests with its own PostgreSQL, and the Playwright suite, on the pull request.

What `test_sessions.py` covers

Requirement	Tests
Logout invalidates the old cookie	The real Google callback (only Google's answer replaced) issues a cookie; after logout, the same cookie gets 401 on `/api/me` and `/api/history`, and the row is gone. Logging out on one device leaves the other signed in. Signing in again replaces the browser's old session
Expired session refused	With a fake clock: used every 12 hours, still refused at exactly 7 days; refused after 24 hours unused but kept alive by use; `last_seen` written at most every 5 minutes; expired rows deleted at the next sign-in
Forged or tampered cookie refused	Seven variants, each also checked on `/api/progress` and `/api/attempts`: an old cookie with a user ID, a made-up session ID, the wrong signing key, a payload changed after signing, an unsigned cookie, a session ID that is not text, a broken signature. A genuine session still works afterwards. The table's own digest used as a cookie is also refused
Deleted user	After the user is deleted, their cookie gets 401 and the row is removed. A migration test checks the database cascade on SQLite and PostgreSQL
Every authenticated route still works	Each of the 11 authenticated routes returns 200 with a live session of the right role
A new route that skips the session check fails	Every route must be listed as public (8 routes) or authenticated (11). Listed as authenticated, it must return 401 with no cookie, an old-format cookie, a logged-out session and an idle-expired one
No logging	No session ID, digest, cookie, email or user ID in any log record

Controls (proving the tests catch mistakes)

I broke the code on purpose, ran the tests, then restored it:

Deliberate break	Result
Added `GET /api/unchecked` with no session check	Route-list test **failed**. After listing it as authenticated, the 401 test **failed** for that route
Logout only empties the cookie (the old behaviour)	Both logout tests **failed**
No expiry and no deleted-user check	14 tests **failed** (both expiry tests, the deleted-user test, and the 401 test for all 11 routes)

8. Mocks and unverified behaviour

- **Google:** in tests, only `oauth.google.authorize_access_token` is replaced, so Google's answer is fixed. The callback route, session creation and cookie are real. The real Google round trip was not run; your live check covers it.
- **Time:** expiry tests use a fake clock (`sessions.clock`) instead of waiting 24 hours or 7 days.
- **Test sign-in:** the route-list and forged-cookie tests insert session rows directly, with the same fields `sessions.start()` writes. The logout, expiry and logging tests go through the real callback.
- **Databases:** most backend tests use SQLite. The migration tests, including the cascade test, also ran on PostgreSQL 16 locally, and CI runs them.
- **The local `curl` check** created its session with `sessions.start()`, not Google.
- **The Playwright tests mock the API**, as before. The frontend did not change.
- **Not verified:** Render's zero-downtime switch with the two versions overlapping (section 5), and cookie behaviour in Safari and Firefox (cookie flags are unchanged).

9. Questions for the owner

1. **Lifetimes:** are 7 days absolute and 24 hours idle right for testers and a classroom? Shorter idle (for example 2 hours) is safer on shared computers but means more sign-ins.
2. **"Sign out everywhere":** do you want a button that ends all of an account's sessions, for a lost phone? It is a small follow-up, not in this PR.

10. Live checks for you after merging

Merging redeploys both services and signs everyone out once. Use a terminal for the `curl` lines.

- [ ] **Deploy finished.** In Render → **python-academy-api** → Logs, find `Database schema is at migration 0006`. Then `curl -s https://python-academy-dji8.onrender.com/health` returns `{"status":"ok"}`.
- [ ] `CLIENT_IP_HEADER` **kept.** Render → python-academy-api → Environment still shows `CLIENT_IP_HEADER = cf-connecting-ip`, and `RATE_LIMIT_DIAGNOSTIC` is absent. If you sync the Blueprint, it should report no change for this variable.

- [ ] **Signed out once.** Open the app in a browser where you were signed in. You see the welcome screen. Sign in with Google: it works, and you land on your usual home.
- [ ] **A copied cookie stops working at logout.** Signed in on the Mac, open DevTools → Application → Cookies → `https://python-academy-dji8.onrender.com` and copy the value of `session`. Do not paste it into a chat while you are signed in. In a terminal:

```
sh URL=https://python-academy-dji8.onrender.com C='paste-the-cookie-value-here' curl -s -o /dev/null -w "%{http_code}\n" -b "session=$C" "$URL/api/me"
```

It prints `200`. Click **Sign out** in the app, then run the same `curl` line again. It prints `401`. Before this PR it would still have printed `200`. - [ ] **Other devices stay signed in.** Sign in on the phone and on the Mac. Sign out on the Mac. Refresh on the phone: still signed in. - [ ] **History.** Sign in again and open "Your account history": the latest entries are "signed in" and, before it, "signed out". - [ ] **Everything signed-in still works.** As a student: open a lesson, run and check a correct answer (badge and XP as before), open the goal card and cancel. As a parent: the family list loads, and creating an invitation works. - [ ] **Logs hold no session data.** In Render → API → Logs, search for your email address, and for a 10-character piece from the middle of the cookie value you copied. Neither appears. - [ ] **Not live-testable quickly:** the 24-hour and 7-day limits. The backend tests cover them with a fake clock. Optionally, leave a browser signed in and unused for more than 24 hours; it should then show the welcome screen.

11. Next concrete action

The owner reviews this PR, merges it, and runs section 10. Then, following the backlog: SEC-09 (CSP nonces), and the switch of the page CSP to enforce mode after a week of clean consoles (handoff 06 section 4). Then FB-01 (decisions 14 and 17).